

Rapport de Workshop en Sécurité Informatique (Synthèse des Fascicules 1 à 6)

Chaouachi Amine

Nemri Yessine

Mahmoud Oumaima

Allani Oumayma

Année Universitaire : 2025–2026

23 juin 2026

Table des matières

1	Introduction et Fondations de la Sécurité	4
1.1	Contexte et Objectifs	4
1.2	Les Services Fondamentaux de Sécurité (DICP)	4
2	Fascicule 1 : Analyse des Vulnérabilités	5
2.1	Préparation de l'Environnement de Workshop	5
2.2	Scan Nmap	5
2.2.1	Identification et Analyse Réseau	5
2.3	Nessus Vulnerability Scanner	5
2.3.1	Installation et Configuration de Nessus	6
2.3.2	Exécution et Rapport d'Analyse	6
3	Fascicule 2 : Les Attaques Informatiques	7
3.1	Attaque ARP Spoofing (Usurpation d'identité)	7
3.1.1	Mise en œuvre et Observation	7
3.2	Attaque Sniffing Man In The Middle (MITM)	7
3.2.1	Interception de Session et Données	7
3.3	Attaques par Déni de Service (DoS/DDoS)	8
3.3.1	Attaque TCP SYN Flooding (DoS)	8
3.3.2	Attaque Smurf (DDoS)	8
3.4	Attaque Social Engineering	8
4	Fascicule 3 : La Cryptographie avec OpenSSL	9
4.1	Chiffrement Symétrique	9
4.1.1	RC4 et DES	9
4.2	Chiffrement Asymétrique (RSA)	9
4.2.1	Génération de la Paire de Clés	9
4.2.2	Chiffrement et Déchiffrement de Données	10
4.3	Signature Numérique (Hachage et Non-Répudiation)	10
4.3.1	Génération de l'Empreinte (Hachage)	10
4.3.2	Signature et Vérification	10
4.4	Certificat Numérique	10
5	Fascicule 4 : Installation et Configuration de pfSense (Firewall)	12
5.1	Architecture de Configuration	12
5.2	Installation et Configuration des Interfaces	12
5.3	Configuration des Règles de Sécurité	13
5.3.1	Exemple de Règles Implémentées	13
5.4	Test des Règles de Sécurité	14

6	Fascicule 5 et 6 : IDS/IPS et VPN	15
6.1	Mise en place d'une solution IDS/IPS [Snort]	15
6.1.1	Installation de Snort	15
6.1.2	Test et Alertes	16
6.2	Mise en place d'une solution VPN [OpenVPN]	17
6.2.1	Configuration et Établissement du Tunnel	17
6.2.2	Visualisation du Trafic	17
7	Conclusion et Synthèse des Acquis	18
7.1	Synthèse des Compétences Développées	18
7.2	Défis Actuels et Perspectives Futures (Intégration SOC et NGFW)	18

Table des figures

2.1	Capture d'écran commentée : 3	5
2.2	Capture d'écran commentée : 3	6
2.3	Capture d'écran commentée : 3	6
3.1	Capture d'écran commentée : 3	7
3.2	Capture d'écran commentée : 3	7
3.3	Capture d'écran commentée : 3	8
3.4	Capture d'écran commentée : 3	8
3.5	Capture d'écran commentée : 3	8
4.1	Capture d'écran commentée : 3	9
4.2	Capture d'écran commentée : 3	9
4.3	Capture d'écran commentée : 3	10
4.4	Capture d'écran commentée : 3	10
4.5	Capture d'écran commentée : 3	10
4.6	Capture d'écran commentée : 3	11
5.1	Schéma de l'architecture pfSense (WAN, LAN, DMZ)	12
5.2	Règle de pare-feu sur le LAN	13
5.3	Règle de pare-feu sur le LAN	14
6.1	Configuration de SNORT	15
6.2	Configuration de SNORT 2	16
6.3	Rapport d'alertes Snort après un test ICMP	16
6.4	Capture d'écran commentée : 3	17
6.5	Capture d'écran commentée : 3	17

Chapitre 1

Introduction et Fondations de la Sécurité

1.1 Contexte et Objectifs

La sécurité informatique est l'ensemble des moyens techniques, pratiques et humains destinés à protéger les systèmes informatiques, les réseaux et les données contre les accès non autorisés, les dommages ou les vols. L'objectif principal est de réduire les risques pesant sur le système d'information pour limiter leurs impacts sur le fonctionnement et les activités métiers des organisations.

1.2 Les Services Fondamentaux de Sécurité (DICP)

Les mécanismes de sécurité visent à garantir les propriétés suivantes sur les biens du Système d'Information (S.I.) :

- **Confidentialité** : Propriété des biens de n'être accessibles qu'aux personnes autorisées.
- **Intégrité** : Propriété d'exactitude et de complétude des biens et informations, permettant de détecter et de corriger une modification illégitime.
- **Disponibilité** : Propriété d'accessibilité au moment voulu des biens par les personnes.
- **Preuve/Traçabilité** : Permet de retrouver les circonstances dans lesquelles un bien évolue, incluant l'Authentification et la Non-répudiation (l'entité ne peut pas nier ses actions dans le S.I.).

Chapitre 2

Fascicule 1 : Analyse des Vulnérabilités

Ce fascicule a consisté à préparer l'environnement de travail et à utiliser des outils de reconnaissance pour identifier les failles potentielles.

2.1 Préparation de l'Environnement de Workshop

L'environnement de travail est basé sur **VMware Workstation Pro / Player**, utilisant une machine attaquante **Kali Linux** et une machine cible/victime **Metasploitable2-Linux** [8, 9].

2.2 Scan Nmap

Nmap est un scanner de ports open source qui permet de détecter les ports ouverts, les services hébergés et les informations sur le système d'exploitation d'un ordinateur cible [10].

2.2.1 Identification et Analyse Réseau

2

FIGURE 2.1 – Capture d'écran commentée: 3

Commentaires: 8cmRésultats du balayage Nmap pour l'identification des services et de l'OS

1. L'analyse rapide des machines a été effectuée en utilisant la commande 'ifconfig' pour obtenir les adresses IP, suivie de la commande 'nmap' [10].
2. Nous avons identifié le système d'exploitation de la machine cible [11].
3. L'état des ports 22 et 443 sur les machines du réseau a été vérifié [11].

2.3 Nessus Vulnerability Scanner

Nessus est un outil d'analyse de vulnérabilité [12]. L'exploitation d'une vulnérabilité par un élément menaçant peut avoir un impact important sur l'organisme [13].

2.3.1 Installation et Configuration de Nessus

2

FIGURE 2.2 – Capture d’écran commentée: 3

Commentaires: 8cmInstallation du package Nessus et activation du service Les étapes suivantes ont été réalisées sur Kali Linux [11] :

1. Téléchargement et installation du package Nessus via ‘sudo dpkg -i’ [11].
2. Démarrage et vérification du service via ‘systemctl start nessusd.service’ et ‘systemctl status nessusd.service’ [14].
3. Finalisation de l’installation via l’interface Web sur le port 8834 et activation du produit (Nessus Essentials) [14].

2.3.2 Exécution et Rapport d’Analyse

2

FIGURE 2.3 – Capture d’écran commentée: 3

Commentaires: 8cmExécution d’une analyse de vulnérabilité sur la machine cible Metasploitable2 Le processus a impliqué la création d’une nouvelle analyse d’agent, la configuration des paramètres de numérisation, l’exécution immédiate, et la création d’un rapport d’analyse dans divers formats (exportation) [15].

Chapitre 3

Fascicule 2 : Les Attaques Informatiques

Ce chapitre documente la concrétisation de menaces par l'exploitation de vulnérabilités [16], incluant les attaques d'accès et les attaques par déni de service (DoS/DDoS) [17].

3.1 Attaque ARP Spoofing (Usurpation d'identité)

L'usurpation d'identité (*spoofing*) est une attaque consistant à prendre l'identité d'une autre personne ou machine pour collecter des données sensibles [18].

3.1.1 Mise en œuvre et Observation

2

FIGURE 3.1 – Capture d'écran commentée: 3

Commentaires: 6cmTable ARP de la victime avant et après l'ARP Spoofing L'attaque a consisté à associer l'@ MAC de la machine attaquante (Kali Linux) à l'@ IP de la Gateway dans la cache ARP de la machine victime [19].

3.2 Attaque Sniffing Man In The Middle (MITM)

Le *sniffing* permet de récupérer toutes les informations transitant sur un réseau [18]. Les attaques MITM visent le vol d'informations, le détournement de session, ou l'analyse du trafic pour obtenir des informations sur le réseau [20].

3.2.1 Interception de Session et Données

2

FIGURE 3.2 – Capture d'écran commentée: 3

Commentaires: 8cmRésultat du Sniffing (MITM) montrant les images interceptées via driftnet L'outil 'ettercap' a été utilisé pour intercepter le flux de communication entre la machine victime et sa passerelle [21].

3.3 Attaques par Déni de Service (DoS/DDoS)

Une attaque DoS vise à rendre un réseau, un hôte ou une application indisponible en surchargeant les ressources jusqu'à provoquer un ralentissement ou un plantage [22].

3.3.1 Attaque TCP SYN Flooding (DoS)

2

FIGURE 3.3 – Capture d'écran commentée: 3

Commentaires: 8cmLancement de l'exploit SYN Flooding via Metasploit Cette attaque consiste à bombarder la machine cible par des paquets TCP SYN avec une adresse IP source falsifiée [23, 24]. Ces paquets créent des connexions semi-ouvertes qui saturent le nombre de connexions disponibles que le serveur est en mesure d'établir [25].

3.3.2 Attaque Smurf (DDoS)

2

FIGURE 3.4 – Capture d'écran commentée: 3

Commentaires: 8cmForgerie de paquets ICMP avec Scapy pour l'attaque Smurf L'attaque Smurf est une attaque DDoS où un grand nombre de paquets ICMP avec l'IP source usurpée de la victime sont diffusés sur un réseau, forçant la cible à recevoir massivement les réponses ICMP ('ICMP replies') [24, 26, 27].

3.4 Attaque Social Engineering

2

FIGURE 3.5 – Capture d'écran commentée: 3

Commentaires: 7cmExemple d'attaque de Social Engineering (Credential Harvester Attack method) Le fascicule a documenté l'attaque d'ingénierie sociale, visant à obtenir des informations personnelles confidentielles [28], via des méthodes comme le *Web site fishing* (Credential Harvester Attack method) ou l'utilisation d'un lien piégé [29, 30].

Chapitre 4

Fascicule 3 : La Cryptographie avec OpenSSL

Ce chapitre couvre l'utilisation de la suite logicielle OpenSSL pour implémenter les services fondamentaux de la sécurité (chiffrement, hachage, signature et certification) [31].

4.1 Chiffrement Symétrique

Le chiffrement symétrique utilise une seule clé secrète pour chiffrer et déchiffrer les données [32].

4.1.1 RC4 et DES

2

FIGURE 4.1 – Capture d'écran commentée: 3

Commentaires: 6cmChiffrement et déchiffrement avec l'algorithme symétrique DES
Le chiffrement et le déchiffrement du fichier 'fichier_{nom}eleve'onttraliséenutilisantla commande'openssl
35].Lavriificationdel'identitdufichierdchiffraufichierinitialestefectueaveclacommande'diff'[3

4.2 Chiffrement Asymétrique (RSA)

Le chiffrement asymétrique utilise une paire de clés complémentaires : une clé publique (pour chiffrer ou vérifier une signature) et une clé privée (pour déchiffrer ou signer) [36].

4.2.1 Génération de la Paire de Clés

2

FIGURE 4.2 – Capture d'écran commentée: 3

Commentaires: 8cmGénération et affichage de la paire de clés RSA 1024 bits Une
paire de clés RSA de taille 1024 bits a été générée et stockée dans le fichier 'rsakey.pem'

en utilisant ‘openssl genrsa’ [37]. La clé publique a été extraite et sauvegardée dans ‘rsapubkey.pem’ [38].

4.2.2 Chiffrement et Déchiffrement de Données

2

FIGURE 4.3 – Capture d’écran commentée: 3

Commentaires: 7cmChiffrement d’un fichier clair avec la clé publique RSA Le chiffrement du fichier clair est réalisé avec la clé publique (‘rsapubkey.pem’), garantissant la confidentialité, en utilisant l’instruction ‘openssl pkeyutl -pubin -inkey... -encrypt’ [39, 40]. Le déchiffrement a utilisé la clé privée (‘rsakey.pem’) [41].

4.3 Signature Numérique (Hachage et Non-Répudiation)

4.3.1 Génération de l’Empreinte (Hachage)

Une fonction de hachage transforme les données en une empreinte de taille fixe, garantissant l’intégrité [42]. **Commentaires:** 7cmCalcul de l’empreinte du fichier à l’aide des

2

FIGURE 4.4 – Capture d’écran commentée: 3

algorithmes de hachage MD5 et SHA1 Les empreintes (digests) du fichier ont été calculées à l’aide des algorithmes MD5 et SHA1 en utilisant la commande ‘openssl dgst’ [43].

4.3.2 Signature et Vérification

La signature numérique assure l’origine et l’intégrité d’un message [44]. **Commen-**

2

FIGURE 4.5 – Capture d’écran commentée: 3

taires: 7cmSignature du fichier avec la clé privée et vérification de la signature avec la clé publique L’empreinte a été signée avec la clé privée en utilisant ‘openssl rsautl -sign’ [45]. La vérification a été effectuée en déchiffrant la signature avec la clé publique (‘rsapubkey.pem’) via ‘openssl rsautl -verify’ [46, 47].

4.4 Certificat Numérique

Un certificat numérique est un document crypté et signé qui lie une clé publique à l’identité de son propriétaire, garantissant l’authenticité [48, 49]. **Commentaires:** 7cm-

FIGURE 4.6 – Capture d'écran commentée: 3

Création d'un certificat auto-signé et affichage de son contenu X.509 Les étapes incluent la génération de la clé privée ('server_{cl}.pem'), la création d'une requête de signature de certificat (CSR), et la signature du certificat par une Autorité de Certification (AC) [46, 50]. Le contenu du certificat est affiché en texte brut.

Chapitre 5

Fascicule 4 : Installation et Configuration de pfSense (Firewall)

Ce fascicule a porté sur la mise en place d'une contre-mesure technique, le pare-feu, qui permet d'appliquer la politique de sécurité en filtrant le trafic entre des zones de confiance différente.

5.1 Architecture de Configuration

```
*** Welcome to pfSense 2.7.2-RELEASE (amd64) on pfSense ***

WAN (wan)      -> em0      -> v4/DHCP4: 192.168.150.132/24
LAN (lan)      -> em1      -> v4: 192.168.11.1/24
OPT1 (opt1)    -> em2      -> v4: 192.168.12.1/24
```

FIGURE 5.1 – Schéma de l'architecture pfSense (WAN, LAN, DMZ)

L'architecture a été déployée sur VMWare Workstation Pro, configurant pfSense avec trois interfaces réseau :

- **WAN (em0)** : Connectée à Internet, configurée en mode *NAT* avec IP dynamique
- **LAN (em1)** : Réseau interne (192.168.11.0/24), utilisant l'IP 192.168.11.1 comme passerelle par défaut.
- **DMZ (em2)** : Zone Démilitarisée (192.168.12.0/24), pour héberger les serveurs publics. La DMZ est une zone de réseau privée isolée pour empêcher l'accès du réseau public vers le réseau privé.

5.2 Installation et Configuration des Interfaces

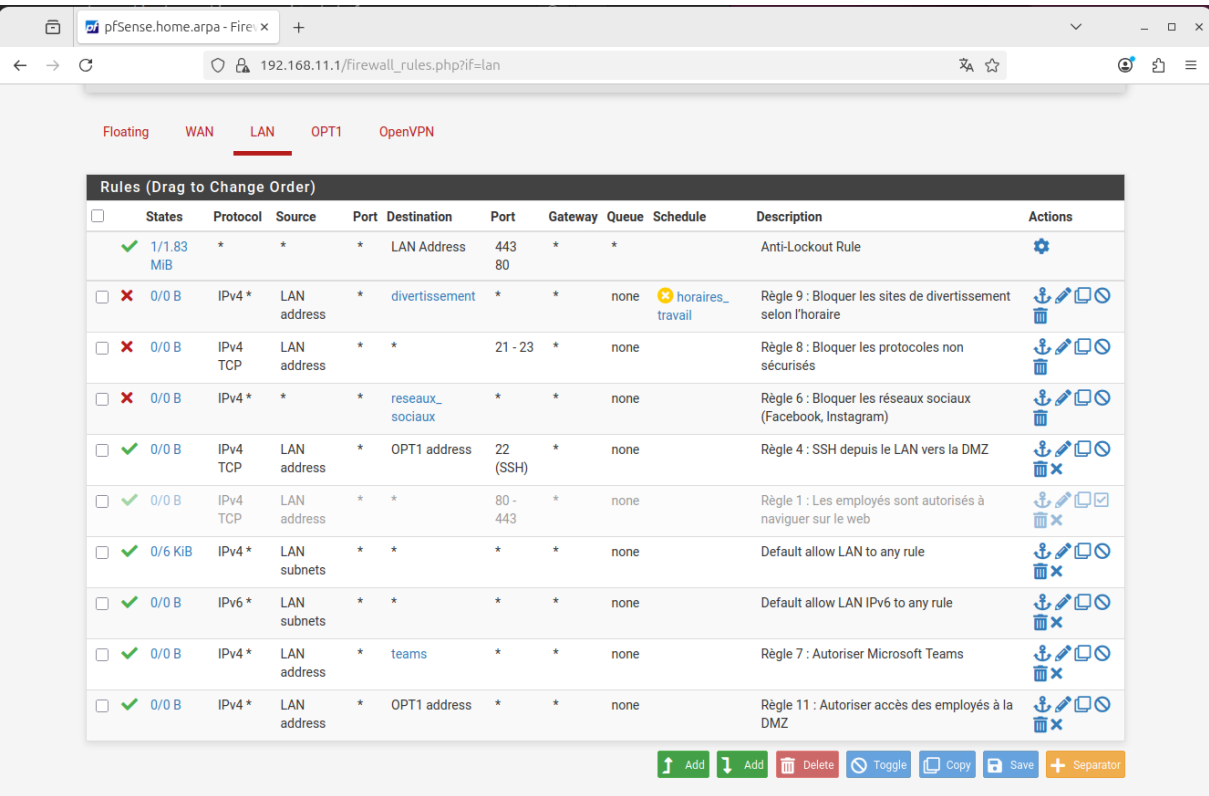
L'installation de pfSense a nécessité l'assignation manuelle des interfaces 'em0' (WAN), 'em1' (LAN) et 'em2' (DMZ) [60]. La configuration de l'adresse IP et du masque de sous-réseau pour les interfaces LAN et DMZ a été réalisée manuellement via le terminal de pfSense.

5.3 Configuration des Règles de Sécurité

La politique de sécurité adoptée est "interdire tout par défaut" (Tout ce qui n'est pas autorisé explicitement est interdit). Ces règles de contrôle d'accès (ACL) ont été configurées via l'interface web de pfSense.

5.3.1 Exemple de Règles Implémentées

Règles sur le réseau LAN



Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	1/1.83 MIB	*	*	*	LAN Address	443 80	*	*		Anti-Lockout Rule	
☐	✗ 0/0 B	IPv4 *	LAN address	*	divertissement	*	*	none	☀ horaires_ travail	Règle 9 : Bloquer les sites de divertissement selon l'horaire	
☐	✗ 0/0 B	IPv4 TCP	LAN address	*	*	21 - 23	*	none		Règle 8 : Bloquer les protocoles non sécurisés	
☐	✗ 0/0 B	IPv4 *	*	*	reseaux_ sociaux	*	*	none		Règle 6 : Bloquer les réseaux sociaux (Facebook, Instagram)	
☐	✓ 0/0 B	IPv4 TCP	LAN address	*	OPT1 address	22 (SSH)	*	none		Règle 4 : SSH depuis le LAN vers la DMZ	
☐	✓ 0/0 B	IPv4 TCP	LAN address	*	*	80 - 443	*	none		Règle 1 : Les employés sont autorisés à naviguer sur le web	
☐	✓ 0/6 KiB	IPv4 *	LAN subnets	*	*	*	*	none		Default allow LAN to any rule	
☐	✓ 0/0 B	IPv6 *	LAN subnets	*	*	*	*	none		Default allow LAN IPv6 to any rule	
☐	✓ 0/0 B	IPv4 *	LAN address	*	teams	*	*	none		Règle 7 : Autoriser Microsoft Teams	
☐	✓ 0/0 B	IPv4 *	LAN address	*	OPT1 address	*	*	none		Règle 11 : Autoriser accès des employés à la DMZ	

Add Add Delete Toggle Copy Save Separator

FIGURE 5.2 – Règle de pare-feu sur le LAN

Ces règles sont implémentées sur le réseau LAN assurant l'autorisation et la restriction sur le flux.

Règles sur le réseau WAN

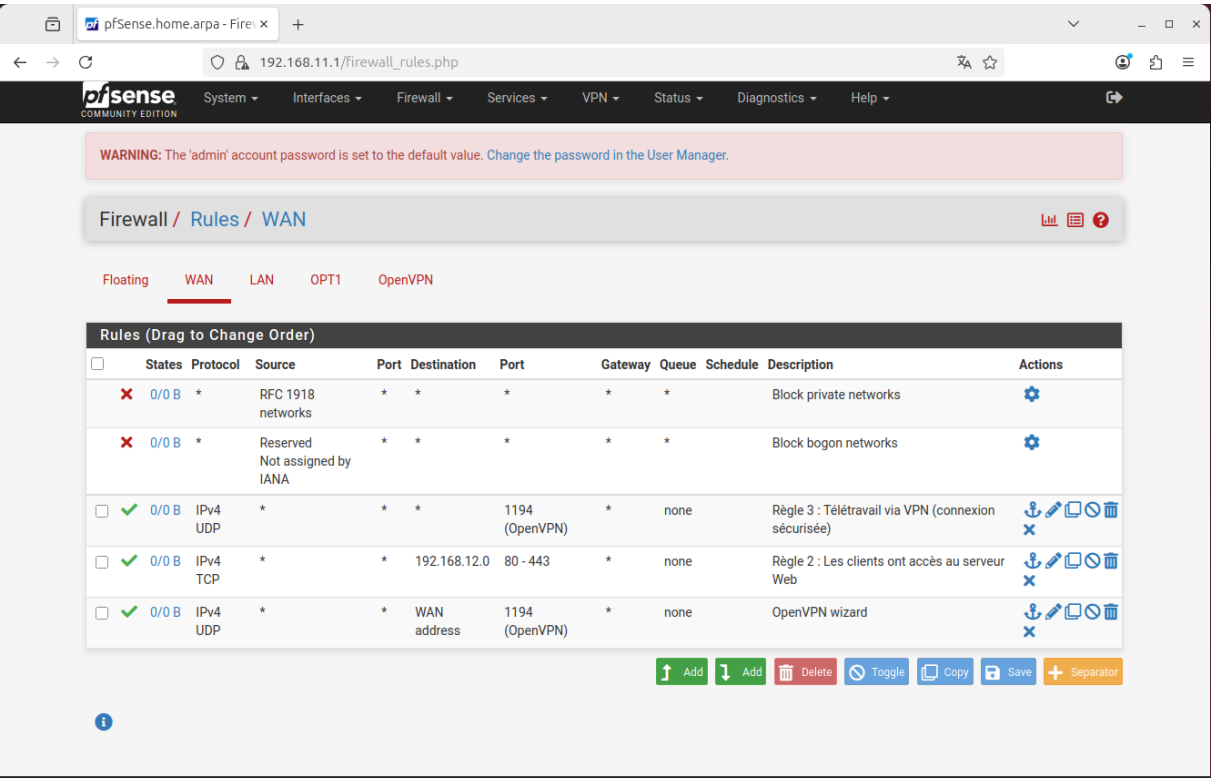


FIGURE 5.3 – Règle de pare-feu sur le LAN

Ces règles sont implémentées sur le réseau WAN assurant l'autorisation et la restriction sur le flux.

5.4 Test des Règles de Sécurité

Des tests ont été réalisés pour valider l'application de chaque règle . Par exemple, le test de la Règle 9 a vérifié que l'accès aux sites de divertissement est bloqué durant les heures de travail spécifiées.

Chapitre 6

Fascicule 5 et 6 : IDS/IPS et VPN

Ces chapitres couvrent l'ajout de mécanismes complémentaires au pare-feu, essentiels pour une stratégie de défense en profondeur.

6.1 Mise en place d'une solution IDS/IPS [Snort]

L'IDS (Intrusion Detection System) a pour fonction de détecter et analyser toute tentative d'effraction, tandis que l'IPS (Intrusion Prevention System) est proactif et vise à empêcher toute activité suspecte détectée [71-73]. Un IDS fonctionne en mode passif (surveillance), tandis qu'un IPS est actif (inline) et bloque immédiatement le trafic suspect [74].

6.1.1 Installation de Snort

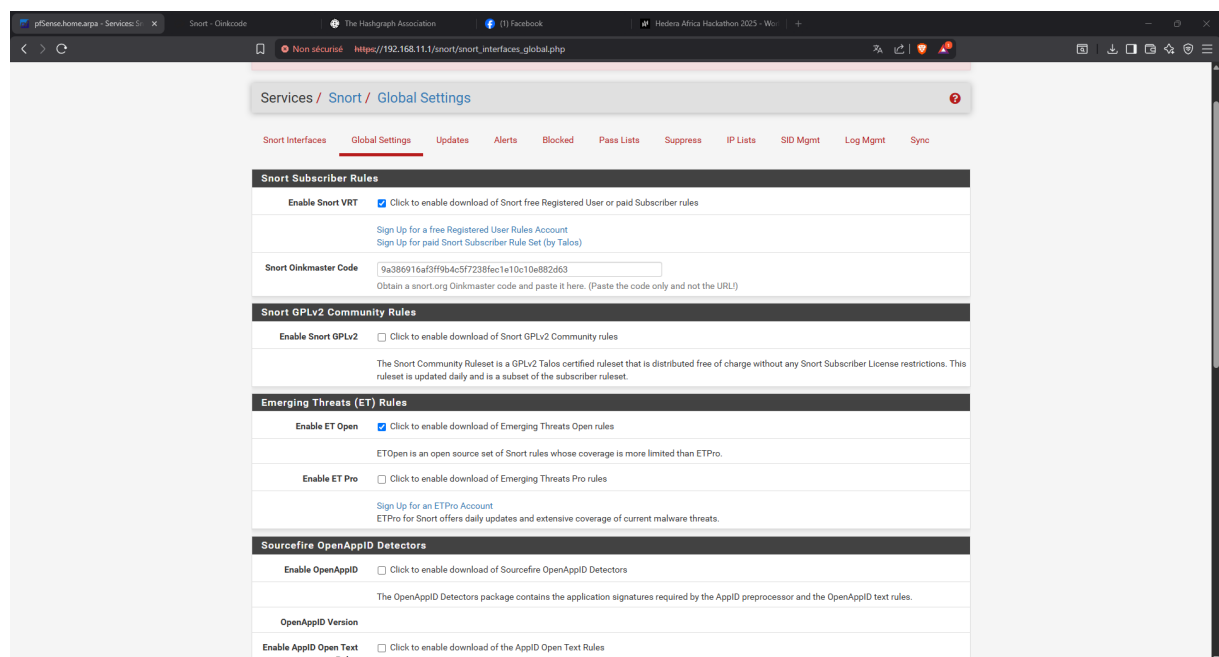


FIGURE 6.1 – Configuration de SNORT

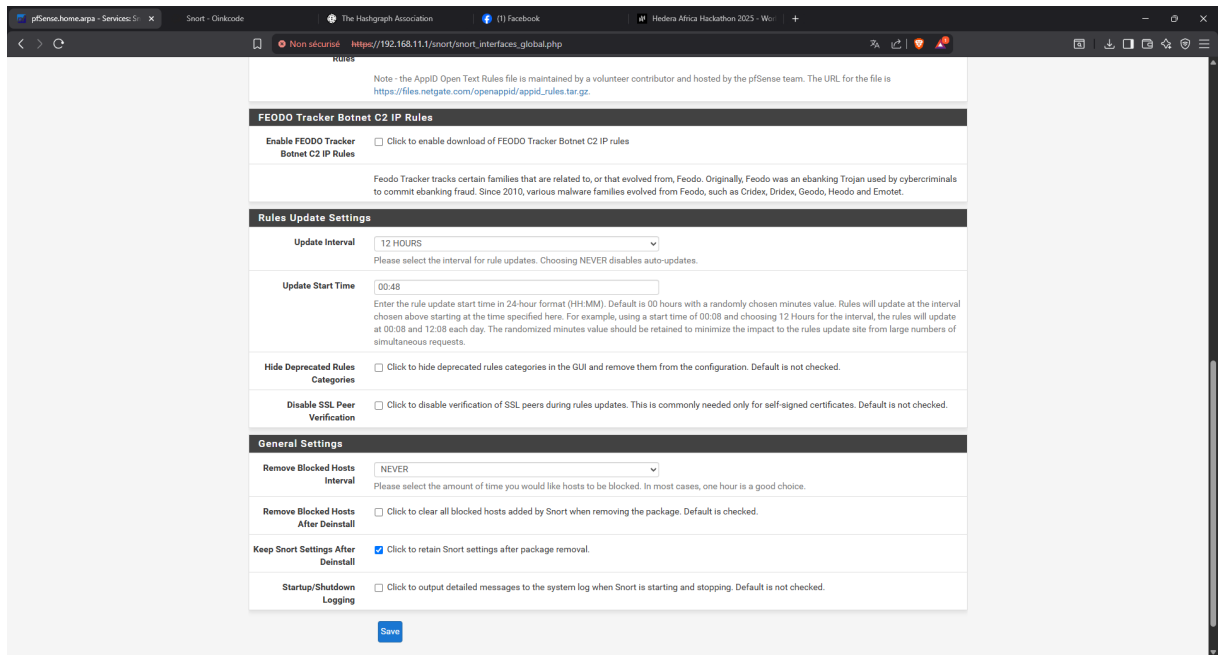


FIGURE 6.2 – Configuration de SNORT 2

6.1.2 Test et Alertes

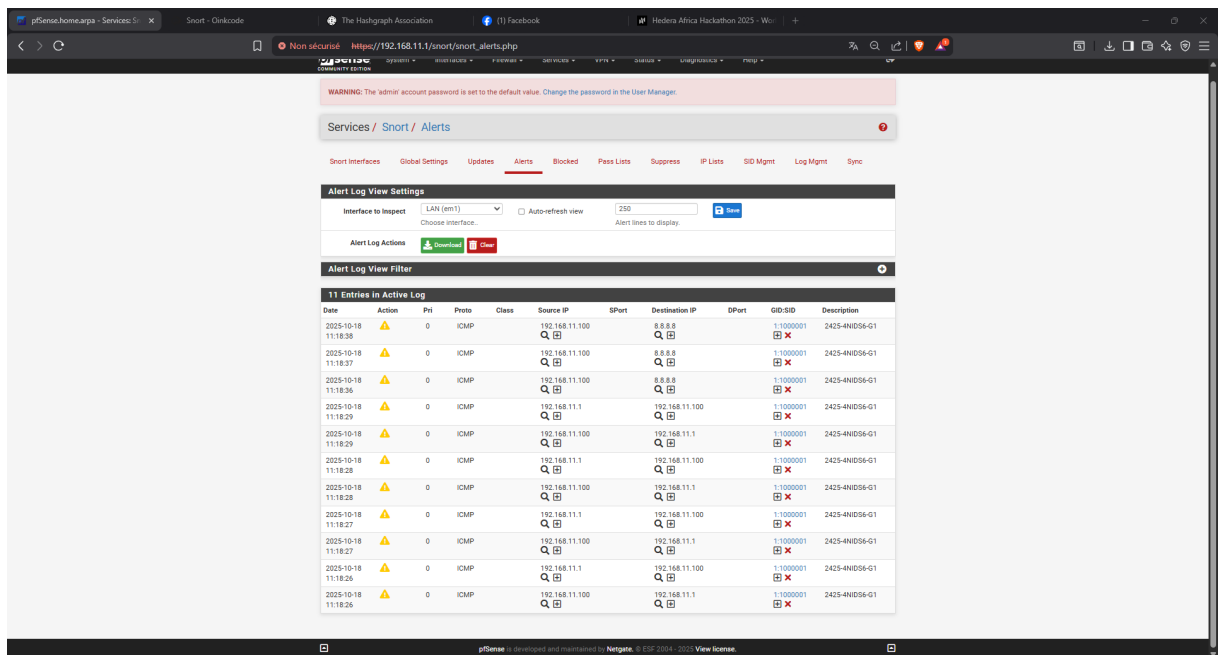


FIGURE 6.3 – Rapport d'alertes Snort après un test ICMP

Une règle de sécurité a été configurée pour détecter spécifiquement le flux ICMP sortant de la zone LAN vers n'importe quelle zone et générer un message d'alerte personnalisé. Cette détection peut s'appuyer sur des signatures, des anomalies ou des règles prédéfinies.

6.2 Mise en place d'une solution VPN [OpenVPN]

Le VPN (Virtual Private Network) est une fonctionnalité complémentaire assurée par le pare-feu qui garantit la confidentialité des communications à distance.

6.2.1 Configuration et Établissement du Tunnel

2

FIGURE 6.4 – Capture d'écran commentée: 3

Commentaires: 7cm Configuration de l'accès VPN client-to-site sur pfSense OpenVPN a été installé et configuré sur les machines LAN et WAN pour permettre une connexion client-à-site.

6.2.2 Visualisation du Trafic

2

FIGURE 6.5 – Capture d'écran commentée: 3

Commentaires: 7cm Capture Wireshark montrant le trafic chiffré de l'établissement du tunnel VPN L'établissement du tunnel VPN entre les deux réseaux LAN et WAN a été testé. L'outil Wireshark a été utilisé pour visualiser le trafic échangé, confirmant que les données sont chiffrées lors de l'établissement du tunnel VPN.

Chapitre 7

Conclusion et Synthèse des Acquis

7.1 Synthèse des Compétences Développées

Ce workshop a permis de maîtriser la méthodologie d'analyse des risques (Vulnérabilité, Menace, Impact, Contre-mesure) de comprendre l'exploitation des failles, et d'implémenter des contre-mesures techniques concrètes.

- **Fondations** : Compréhension et implémentation des services de sécurité DICP (Disponibilité, Intégrité, Confidentialité, Preuve).
- **Reconnaissance et Attaques** : Utilisation d'outils comme Nmap et Nessus pour identifier les services et vulnérabilités, et exécution d'attaques d'accès (MITM) et de déni de service (DoS/DDoS).
- **Cryptographie** : Maîtrise des protocoles OpenSSL pour assurer la Confidentialité (chiffrement symétrique et asymétrique), l'Intégrité (hachage MD5/SHA1), et la Non-répudiation (signature numérique).
- **Défense Périmétrique** : Déploiement d'un pare-feu logiciel (pfSense) avec une segmentation réseau (LAN/WAN/DMZ) et application de la politique stricte d'« **interdire tout par défaut** ».
- **Détection et Prévention** : Intégration et configuration de solutions IDS/IPS (Snort) pour la détection des anomalies et le blocage proactif des intrusions.
- **Accès Sécurisé** : Mise en œuvre du protocole VPN (OpenVPN) pour assurer la confidentialité des communications à distance.

7.2 Défis Actuels et Perspectives Futures (Intégration SOC et NGFW)

Les systèmes de sécurité déployés (Pare-feu, IDS/IPS) s'inscrivent dans une approche de **défense en profondeur**. Cependant, l'évolution constante des menaces et l'augmentation du volume de trafic génèrent de nouveaux défis, notamment dans le contexte des IDS/IPS :

- **Faux Positifs et Négatifs** : Les IDS/IPS restent confrontés aux faux positifs (alertes sur du trafic légitime) et aux faux négatifs (attaques non détectées car nouvelles ou sophistiquées). La qualité des règles et des signatures est donc cruciale.

- **Scalabilité** : Face à la forte croissance du volume de trafic, l'analyse en temps réel de millions de paquets exige de hautes performances matérielles et logicielles pour les systèmes IDS/IPS.
- **NGFW (Next Generation Firewall)** : La tendance est à l'adoption de pare-feux de nouvelle génération, qui combinent la fonction traditionnelle du pare-feu avec des fonctions de sécurité avancées, telles que l'inspection approfondie des paquets (DPI), un **système de prévention d'intrusions (IPS)**, l'inspection anti-malware et le filtrage des sites Web. Ces solutions intègrent les fonctionnalités d'IDS/IPS nativement.
- **Intégration SOC et IA/ML** : Pour améliorer la fiabilité et la détection d'anomalies complexes et inconnues, l'intégration de l'Intelligence Artificielle et du Machine Learning dans les systèmes de détection est un objectif majeur. De plus, l'IDS/IPS s'intègre dans une architecture de sécurité plus large, notamment aux côtés d'outils SIEM (Security Information and Event Management) au sein d'un **SOC (Security Operations Center)** permettant une surveillance et une réponse aux incidents centralisées.